ARX UMBRA

[Vulnerability Management Policy]

Version 1.0 · March 12, 2026

Classification: INTERNAL USE ONLY

DRAFT

§ 1. Policy Overview

This policy establishes the framework for managing vulnerabilities within **Arx Umbra**'s IT infrastructure.

Its purpose is to ensure the security and integrity of all organizational systems through timely identification, honest evaluation, and decisive remediation of threats. **Arx Umbra** takes its responsibilities seriously.

— ✦ —

§ 2. Scope

This policy applies to all IT assets owned or operated by **Arx Umbra**. If it has an IP address and belongs to us, it's in scope. In-scope assets include, but are not limited to:

- Networks and network infrastructure
- Servers and virtual machines
- Endpoints and workstations
- Associated applications and services

— ✦ —

§ 3. Responsibilities

The following roles bear responsibility for the success of this program. They have been informed. They have accepted.

- Chief Information Security Officer (CISO) — **PERSON 1**: Primary overseer of the vulnerability management process. Responsible for ensuring organization-wide policy compliance.
- Chief Information Officer (CIO) — **PERSON 2**: Ensures vulnerability management is woven into **Arx Umbra**'s broader IT strategy.
- Chief Executive Officer (CEO) — **PERSON 3**: Final sign-off authority. PERSON 3 approves the budget.
- Department Heads: Responsible for ensuring compliance within their respective departments.

Routine Scans: Monthly scans of all in-scope IT assets. Scheduled. Recurring. Non-negotiable. Put it in your calendar with a little skull emoji if that helps.

- Ad-Hoc Scans: Triggered by significant security alerts, newly disclosed CVEs.

§ 5. Remediation Schedule and Cadence

Vulnerabilities are prioritized using the Common Vulnerability Scoring System (CVSS).

Critical: (CVSS 9.0 – 10.0)	48 hours. Drop what you are doing. Yes, including lunch.
High: (CVSS 7.0 – 8.9)	7 days. This week. Not next week. This one.
Medium: (CVSS 4.0 – 6.9)	30 days. A full month. Still not forever.
Low: (CVSS 0.1 – 3.9)	90 days. We're watching. Gently, but watching.

§ 6. Maintenance Plans

Say something

- Routine Patching: Security patches and updates applied on a monthly schedule, aligned with the scan cadence.
- Emergency Patching: Initiated within 24 hours for critical vulnerabilities posing immediate risk.
- Emergency Mitigation: Temporary measures — firewall rules, access restrictions, implemented immediately while permanent fixes are developed and tested.
- Unpatchable Assets: Legacy systems that cannot be patched will be segmented, heavily monitored, and placed on the official Phased Retirement List.

§ 7. Non-Compliance Consequences

Say something here.

- First: An immediate review of affected procedures.
- Second: Mandatory retraining for involved personnel.
- Third: Escalation to senior leadership for further disciplinary action, up to and including termination.

§ 8. Sign-Off

By signing below, the undersigned acknowledge that they have read, understood, and accepted this policy.

Chief Information Security Officer (CISO)

Name: **PERSON 1**
Sign: _____
Date: _____

Chief Information Officer (CIO)

Name: **PERSON 2**
Sign: _____
Date: _____

Chief Executive Officer (CEO)

Name: **PERSON 3**
Sign: _____
Date: _____

§ 9. Review and Revision

This policy will be reviewed annually. Revisions will be version-controlled, documented, and distributed as the original.

§ Document Control

- Version: 1.0
- Date: March 12, 2026
- Author: **Arx Umbra** Security Team
- Classification: Internal Use Only
- Status: Active